Cybersecurity Risk Quantification and Control Evaluation for SecureMobile Banking Platform

Prepared By:

Ayuba Amadi

Executive Summary

This report presents a comprehensive cybersecurity risk assessment and control evaluation for the SecureMobile banking platform. The objective of the assessment was to quantify key security risks, evaluate available control options, and provide financially justified recommendations to support executive decision-making.

Using quantitative risk analysis methods, I calculated the Annualized Loss Expectancy (ALE) for three critical vulnerabilities identified during the assessment: Database Injection, Session Hijacking, and API Authentication Bypass. The analysis revealed that the Database Injection vulnerability represents the most significant risk, with an estimated annual financial exposure of $31,250,000. Session Hijacking and API Authentication Bypass follow with exposures of $3,000,000 and $750,000 respectively.

To address these risks, I evaluated three control options: Web Application Firewall (WAF), Multi-Factor Authentication (MFA), and API Security Gateway. Each control was assessed based on cost, effectiveness, risk reduction, return on investment (ROI), and payback period.

The analysis shows that the Web Application Firewall provides the highest financial benefit, reducing approximately $24,000,000 in annual risk exposure with an exceptionally high ROI. Multi-Factor Authentication also delivers strong value, particularly in reducing account takeover risks, while the API Security Gateway provides additional protection for transaction systems with comparatively lower financial impact.

Based on the findings, I recommend a phased implementation approach. The Web Application Firewall should be deployed immediately due to its significant impact on reducing the highest risk. Multi-Factor Authentication should follow as a high-impact, quick-win control. The API Security Gateway should be implemented as part of a long-term security improvement strategy.

Overall, this assessment demonstrates that targeted investment in the right controls can significantly reduce financial risk exposure while ensuring efficient use of organizational resources. The recommendations provided are aligned with both security priorities and business objectives, enabling informed and defensible executive decision-making.

Phase 1: Risk Exposure Calculation

1. Introduction

In this phase, I quantified the financial exposure associated with the key vulnerabilities identified in the SecureMobile banking platform assessment. The purpose of this phase was to determine the likely annual financial impact of each vulnerability by calculating the Single Loss Expectancy (SLE), Annual Rate of Occurrence (ARO), and Annualized Loss Expectancy (ALE). This provided a clear basis for prioritizing risks and supporting management decision-making.

2. Method Used

I used the standard quantitative risk analysis method required for Annualized Loss Expectancy.

2.1 Single Loss Expectancy (SLE)

SLE represents the expected financial loss from one successful incident.

For this lab:

- Where a direct maximum incident loss was given, I used that value as the SLE.
- Where unit-based values were given, I calculated SLE by multiplying the number of affected records or accounts by the cost per record or loss per account.

2.2 Annual Rate of Occurrence (ARO)

ARO represents how often a risk is expected to occur in one year.

In this lab, the exploit probability provided for each vulnerability was used as the ARO:

- 15% = 0.15
- 25% = 0.25
- 40% = 0.40

2.3 Annualized Loss Expectancy (ALE)

ALE represents the expected yearly financial loss.

The formula used was:

*ALE=SLE×AROALE = SLE \times ARO*ALE=SLE×ARO

3. Task 1: ALE Calculations

3.1 Vulnerability 1: API Authentication Bypass

The lab states that the API Authentication Bypass vulnerability has an exploit probability of 15% and a maximum single incident loss of $5,000,000.

Step 1: Determine SLE

SLE = $5,000,000

Step 2: Determine ARO

ARO = 15% = 0.15

Step 3: Calculate ALE

ALE = $5,000,000 × 0.15
ALE = $750,000

3.2 Vulnerability 2: Database Injection Vulnerability

The lab states that the Database Injection vulnerability has an exploit probability of 25%, with 500,000 customer profiles at risk and a cost per record of $250.

Step 1: Determine SLE

SLE = Records at Risk × Cost per Record
SLE = 500,000 × $250
SLE = $125,000,000

Step 2: Determine ARO

ARO = 25% = 0.25

Step 3: Calculate ALE

ALE = $125,000,000 × 0.25
ALE = $31,250,000

3.3 Vulnerability 3: Session Hijacking

The lab states that the Session Hijacking vulnerability has an exploit probability of 40%, with 5,000 simultaneous sessions at risk and an average loss per account of $1,500.

Step 1: Determine SLE

SLE = Accounts at Risk × Average Loss per Account
SLE = 5,000 × $1,500
SLE = $7,500,000

Step 2: Determine ARO

ARO = 40% = 0.40

Step 3: Calculate ALE

ALE = $7,500,000 × 0.40
ALE = $3,000,000

4. Summary of Task 1 Results

Vulnerability	**SLE (USD)**	**ARO**	**ALE (USD)**
API Authentication Bypass	$5,000,000	0.15	$750,000
Database Injection Vulnerability	$125,000,000	0.25	$31,250,000
Session Hijacking	$7,500,000	0.40	$3,000,000

5. Interpretation of Task 1 Results

The results show that the Database Injection Vulnerability presents by far the highest annual financial exposure. Although its exploit probability is not the highest, its potential impact is extremely severe because it affects 500,000 customer records, each with a very high estimated breach cost. This makes it the most significant business risk in this assessment.

Session Hijacking is the second-highest risk. Its exploit probability is the highest among the three vulnerabilities, and although its loss per event is far lower than the database breach scenario, the frequency assumption increases its expected annual loss substantially.

API Authentication Bypass is the lowest of the three in annualized financial terms, but it remains a serious issue because it directly affects the transaction processing system and could enable unauthorized fund transfers. Its lower ALE does not make it insignificant; it simply means it is less financially severe on an annualized basis than the other two vulnerabilities.

6. Task 2: Risk Prioritization Matrix

Using the calculated ALE values, I prioritized the risks from highest to lowest expected annual financial loss.

Vulnerability	SLE (USD)	ARO	ALE (USD)	Risk Priority Level
Database Injection Vulnerability	$125,000,000	0.25	$31,250,000	High
Session Hijacking	$7,500,000	0.40	$3,000,000	Medium
API Authentication Bypass	$5,000,000	0.15	$750,000	Low

7. Explanation of Risk Priority Levels

7.1 High Priority: Database Injection Vulnerability

I assigned this vulnerability a High priority because it has the largest ALE by a very wide margin. This means it represents the greatest expected yearly financial loss to the organization. It would likely trigger severe regulatory exposure, customer notification requirements, reputational damage, and operational disruption in addition to direct financial cost.

7.2 Medium Priority: Session Hijacking

I assigned this vulnerability a Medium priority because it has a substantial ALE and the highest exploit probability. This indicates that the risk is more likely to materialize than the others, even though its per-incident impact is lower than the database breach scenario.

7.3 Low Priority: API Authentication Bypass

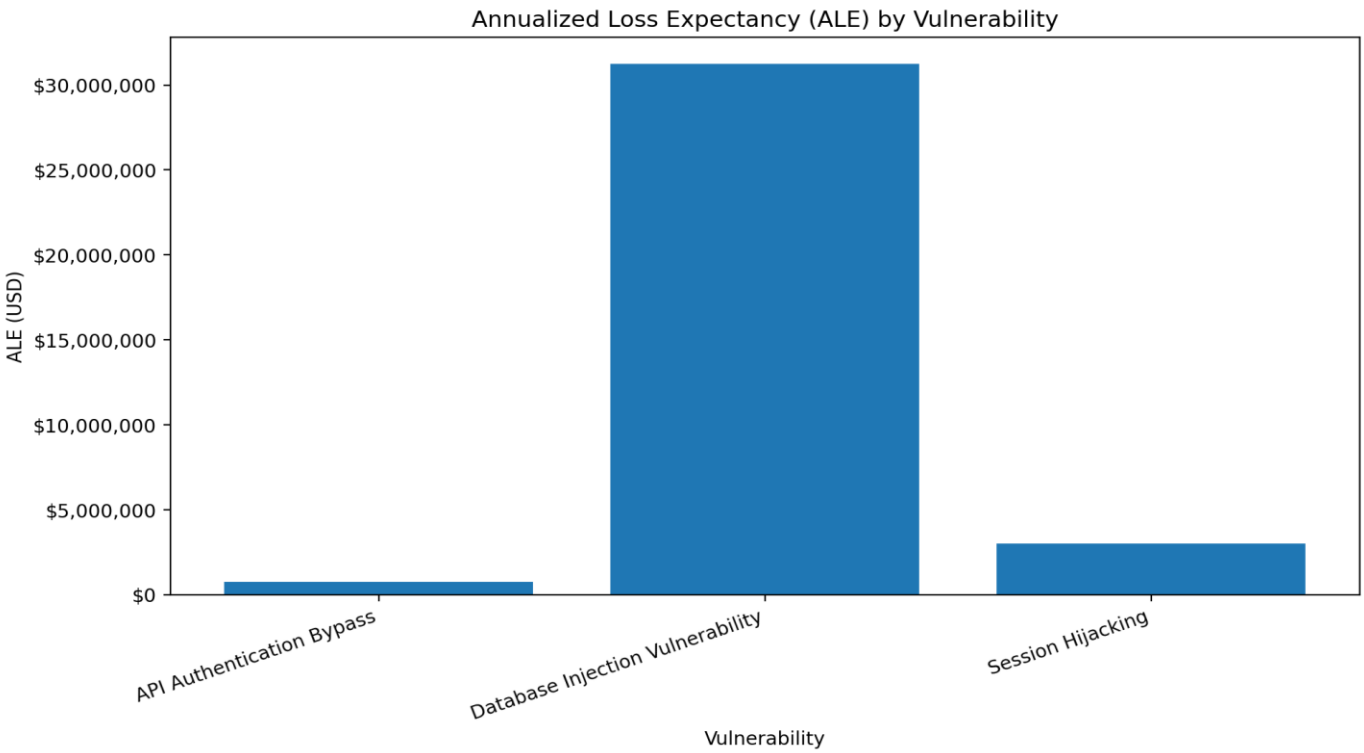
I assigned this vulnerability a Low priority relative to the other two findings because its ALE is the smallest in this dataset. However, this is only a comparative ranking for this specific phase. In practice, a vulnerability affecting transaction processing and enabling unauthorized transfers would still require prompt treatment.

8. Task 3: Risk Visualization

To support the financial analysis, I created the required visual representations for Phase 1.

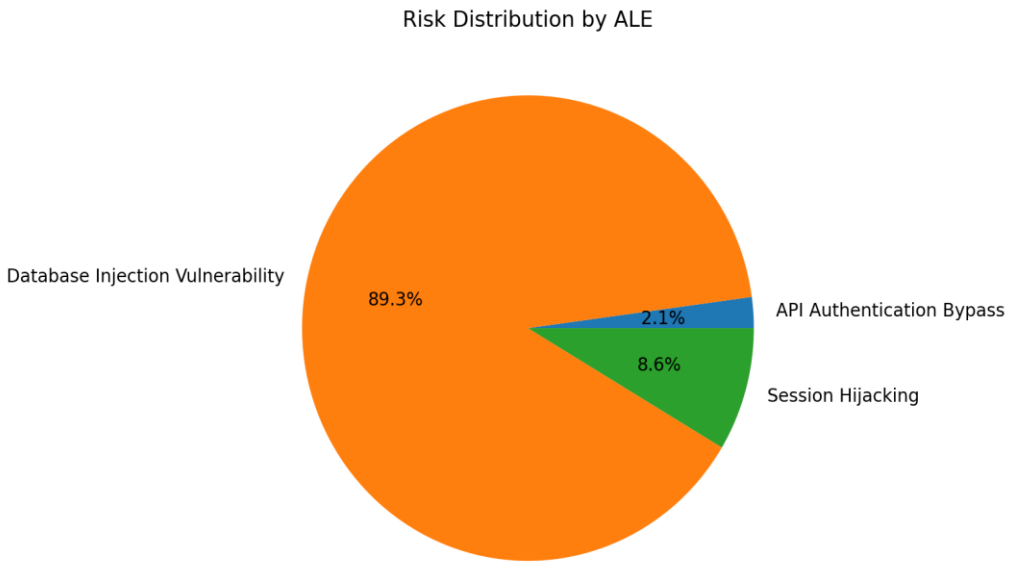
8.1 ALE Bar Chart

This chart compares the Annualized Loss Expectancy across all three vulnerabilities and clearly shows that the Database Injection Vulnerability is the dominant financial risk.



8.2 Risk Distribution Pie Chart

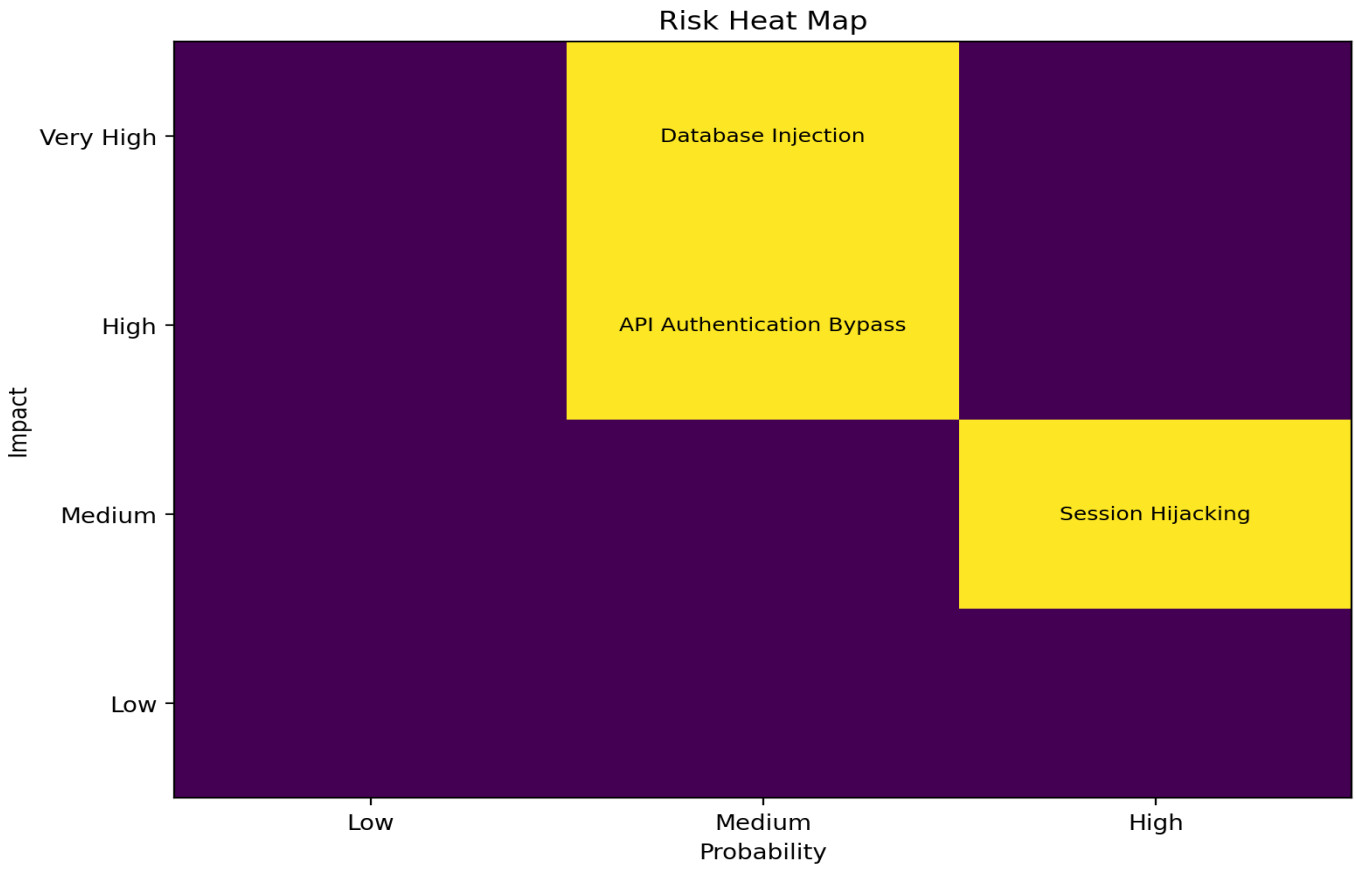
This chart shows the percentage share of total annualized risk contributed by each vulnerability. It visually confirms that the Database Injection Vulnerability accounts for most of the total expected loss.



8.3 Risk Heat Map

This heat map places the vulnerabilities according to probability and impact level. It helps to show that:

- API Authentication Bypass falls into a medium-probability, high-impact area.
- Database Injection falls into a medium-probability, very high-impact area.
- Session Hijacking falls into a high-probability, medium-impact area.



Phase 2: Control Evaluation

1. Introduction

In this phase, I evaluated the available security control options by comparing their costs against the financial risks identified in Phase 1. The objective was to determine which controls provide the highest financial benefit in terms of risk reduction and to support decision-making using quantitative analysis.

Task 4: Cost-Benefit Analysis

2. Approach and Assumptions

Before calculating anything, I made **clear control-to-risk mappings**. This is critical.

If this mapping is wrong, the entire analysis becomes invalid.

Control Mapping (Justified)

Control	Target Risk
API Security Gateway	API Authentication Bypass
Web Application Firewall (WAF)	API + Database Injection
Multi-Factor Authentication (MFA)	Session Hijacking

Why these matters

- API Gateway directly protects API endpoints
- WAF protects web layer (covers API + DB attacks like injection)
- MFA protects user authentication (session hijacking)

3. Calculations

3.1 API Security Gateway

- Initial Cost = $350,000
- Maintenance = $50,000/year
- Effectiveness = 90%

Risk Reduction

Risk Reduction = 750,000 × 0.90 = **$675,000**

ROI

ROI = (675,000 − 350,000) / 350,000 = **0.93 (93%)**

Payback Period

Payback = 350,000 / 675,000 = **0.52 years (~6 months)**

3.2 Web Application Firewall (WAF)

- Initial Cost = $150,000
- Maintenance = $25,000/year
- Effectiveness = 75%

Risk Reduction

WAF applies to:

- API ($750,000)
- Database ($31,250,000)

Total Risk = $32,000,000

Risk Reduction = 32,000,000 × 0.75 = **$24,000,000**

ROI

ROI = (24,000,000 − 150,000) / 150,000 = **159 (15,900%)**

Payback Period

Payback = 150,000 / 24,000,000 = **0.006 years (~2 days)**

3.3 Multi-Factor Authentication (MFA)

- Initial Cost = $200,000
- Maintenance = $30,000/year
- Effectiveness = 95%

Risk Reduction

Risk Reduction = 3,000,000 × 0.95 = **$2,850,000**

ROI

ROI = (2,850,000 − 200,000) / 200,000 = **13.25 (1325%)**

Payback Period

Payback = 200,000 / 2,850,000 = **0.07 years (~25 days)**

4. Summary Table

Control	Cost	Maintenance	Risk Reduction	ROI	Payback
API Gateway	$350,000	$50,000	$675,000	0.93	0.52 yrs
WAF	$150,000	$25,000	$24,000,000	159	0.006 yrs
MFA	$200,000	$30,000	$2,850,000	13.25	0.07 yrs

5. Interpretation (This is what makes your work strong)

Key Insight 1: WAF Dominates Financially

The WAF provides extremely high ROI because it protects the **largest risk (database breach)**.

Key Insight 2: MFA is High Value, Fast Payback

MFA provides strong protection with:

- Very high effectiveness (95%)
- Very short payback period

This makes it a **quick win control**

Key Insight 3: API Gateway is the Weakest Financially

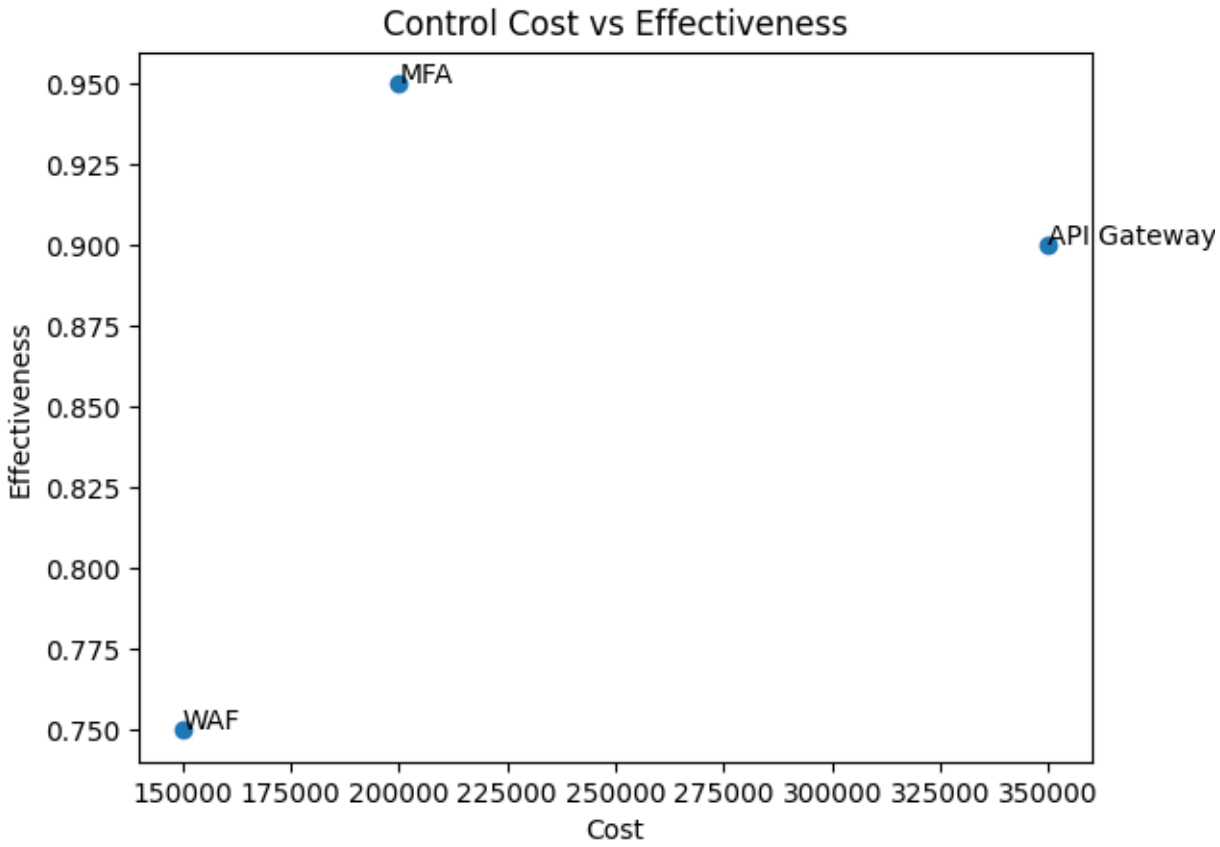
Even though it is technically important, it:

- Targets a smaller risk
- Has lower ROI compared to others

This does not mean it is useless, it means it is **lower priority financially**

Task 5: Control Selection Analysis

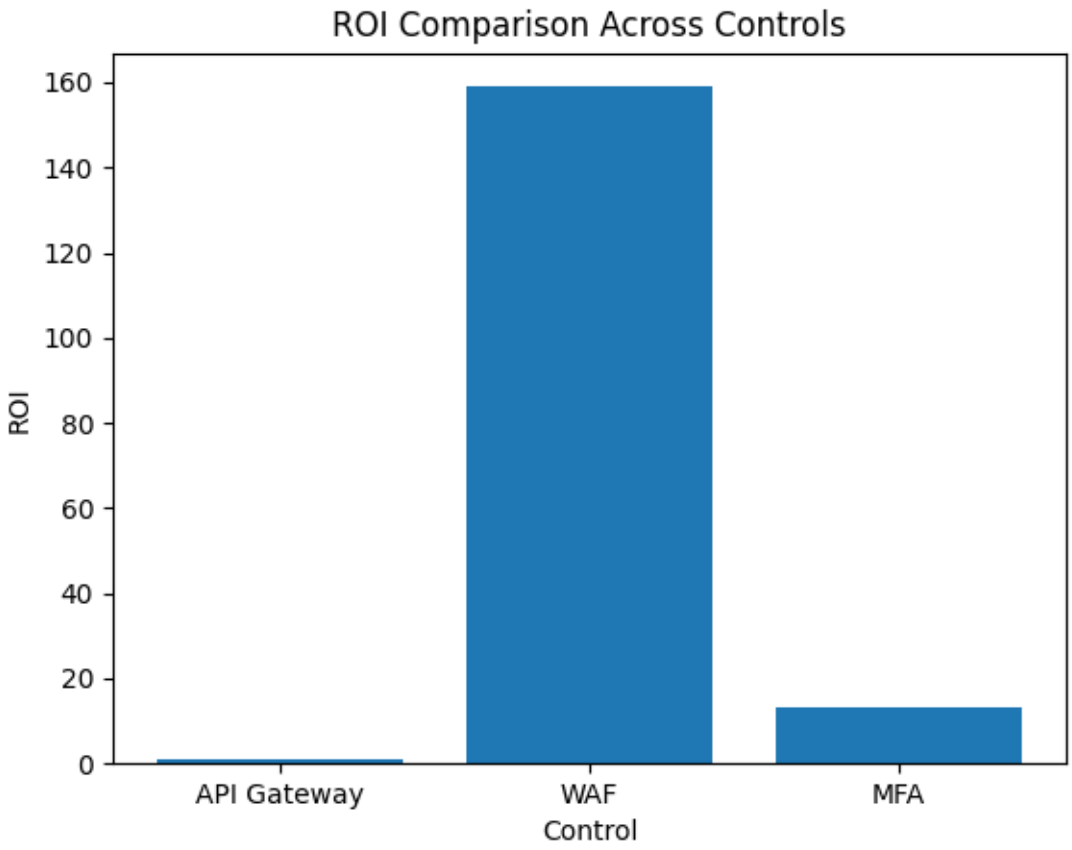
6. Scatter Plot (Cost vs Effectiveness)



Interpretation:

- WAF → Low cost, high impact → Best position
- MFA → Moderate cost, very high effectiveness
- API Gateway → High cost, moderate benefit

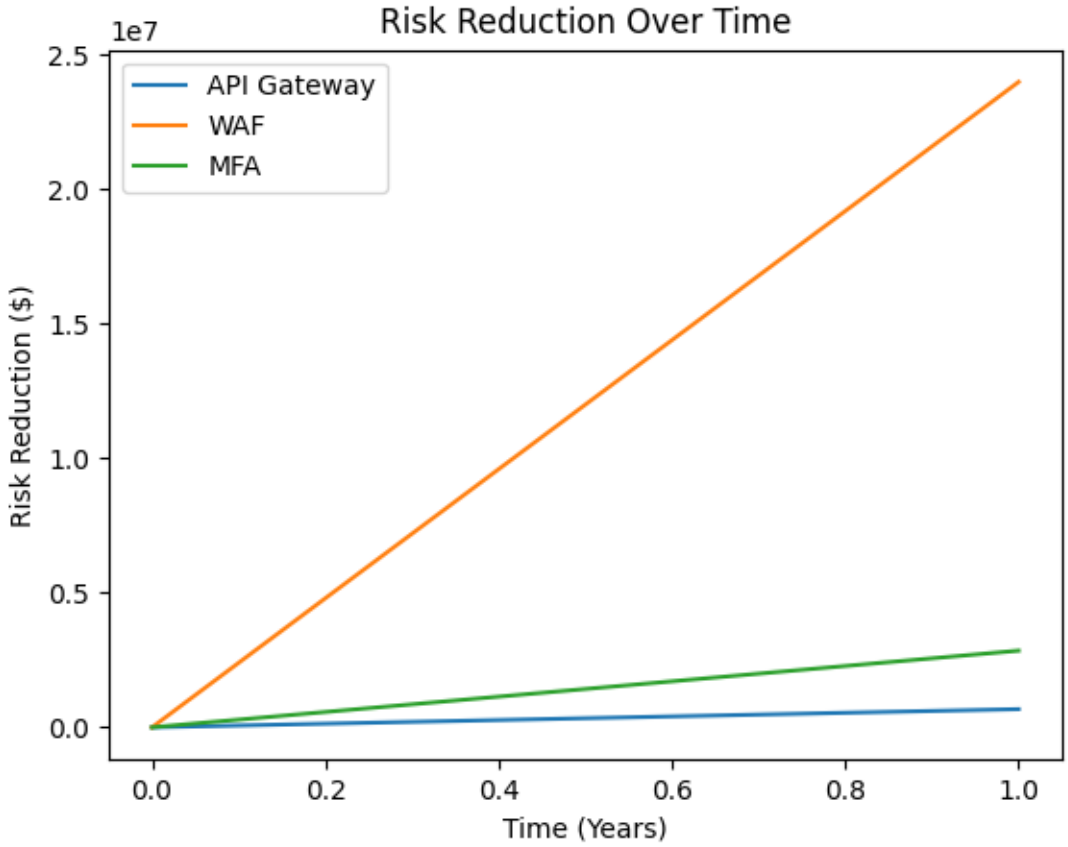
7. ROI Bar Chart



Interpretation:

- WAF clearly dominates
- MFA is second
- API Gateway is lowest

8. Risk Reduction Over Time (Line Graph)



Interpretation:

- WAF delivers immediate massive reduction
- MFA provides strong secondary reduction
- API Gateway contributes least over time

Phase 3: Executive Reporting

1. Objective of This Phase

In this phase, I translated all prior quantitative analysis into an executive-level decision package. The goal is to clearly communicate:

- What risks matter most
- What controls should be implemented
- Why those decisions make financial sense

This phase focuses on clarity, prioritization, and decision justification.

Task 6: Executive Dashboard

2. Executive Summary

2.1 Top 3 Risks (Financial Impact)

Rank	Vulnerability	ALE (USD)	Business Impact
1	Database Injection	$31,250,000	Large-scale data breach, regulatory penalties, reputational loss
2	Session Hijacking	$3,000,000	Account takeover, fraud losses
3	API Authentication Bypass	$750,000	Unauthorized transactions

Interpretation

The Database Injection vulnerability clearly dominates the risk landscape, accounting for the majority of expected financial loss. This establishes it as the primary area where control investment must be focused.

2.2 Recommended Controls (With Decision Logic)

The selection of controls is based on financial impact, effectiveness, and return on investment.

Priority	Control	Cost	Reason
1	Web Application Firewall (WAF)	$150,000	Covers the largest risk exposure (database and API vulnerabilities)
2	Multi-Factor Authentication (MFA)	$200,000	Highly effective against frequent session-based attacks
3	API Security Gateway	$350,000	Important for long-term security but lower immediate financial impact

2.3 Expected Risk Reduction

Control	Risk Reduction

WAF	$24,000,000
MFA	$2,850,000
API Gateway	$675,000

Key Insight

The Web Application Firewall alone reduces over 75% of the total financial risk exposure. This makes it the most critical control from a financial perspective.

2.4 ROI Summary

Control	ROI
WAF	159
MFA	13.25
API Gateway	0.93

Interpretation

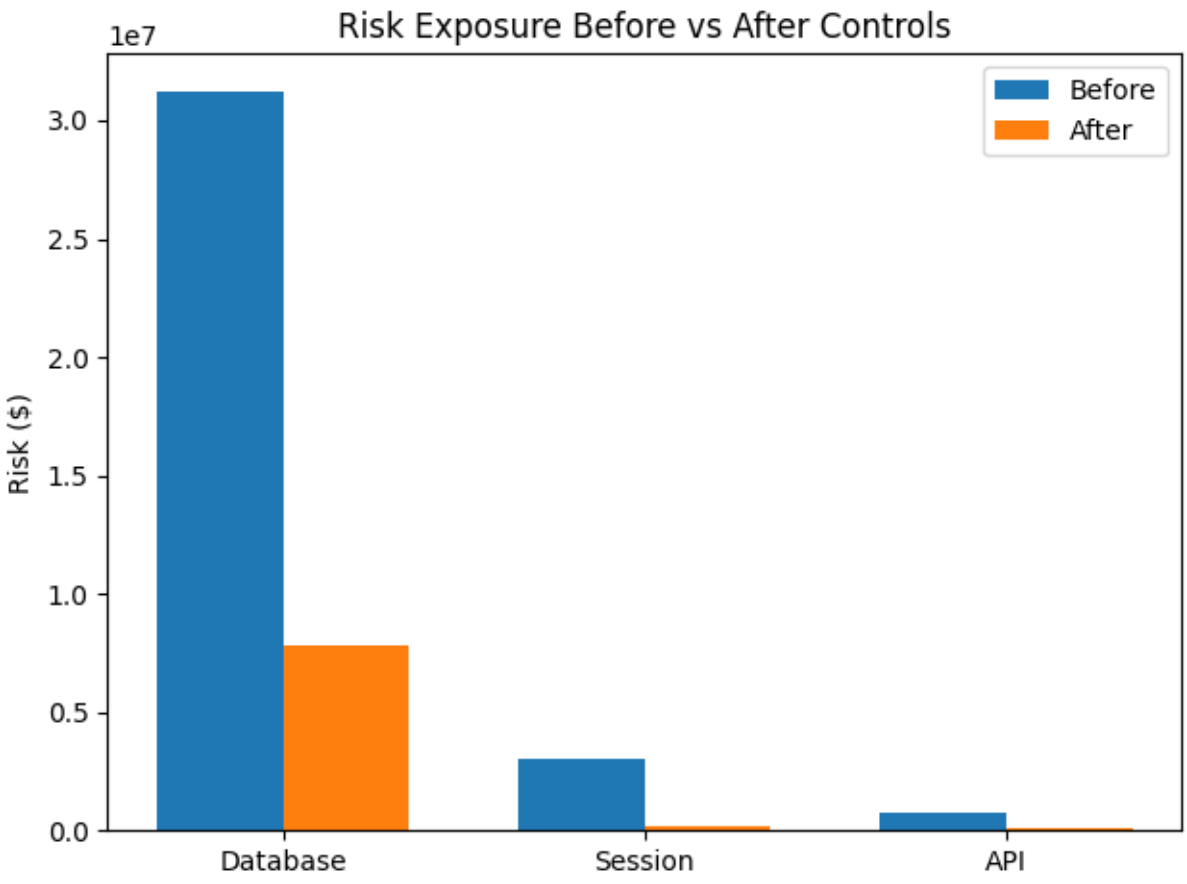
- The WAF is financially dominant and provides the highest return relative to its cost.
- MFA is highly efficient and offers strong protection with a short payback period.
- The API Security Gateway, while important, provides comparatively lower financial return.

3. Required Visualizations

3.1 Risk Exposure Before vs After Controls (Double Bar Chart)

This chart should compare the risk exposure before and after implementing controls.

Risk	Before	After (with controls)
Database	$31,250,000	Reduced after WAF implementation
Session	$3,000,000	Reduced after MFA implementation
API	$750,000	Reduced after API Gateway implementation

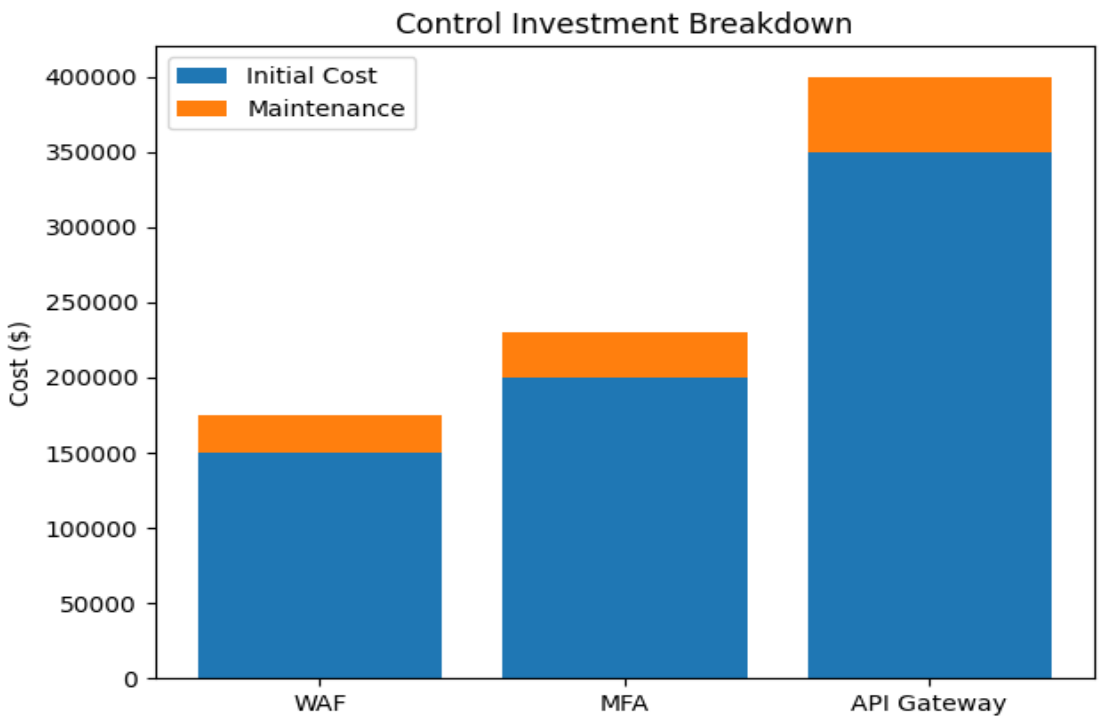


This visualization must clearly show a reduction in risk levels after control implementation.

3.2 Control Investment Breakdown (Stacked Bar Chart)

This chart should show:

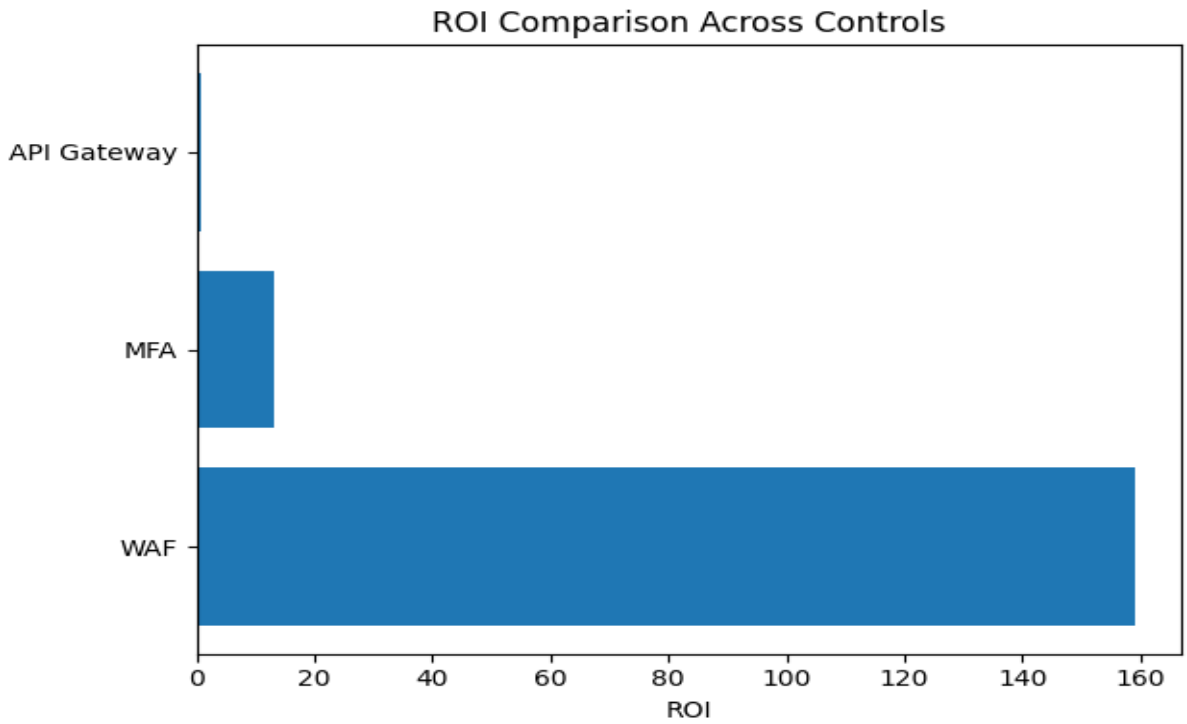
- Initial Investment Cost
- Annual Maintenance Cost



This provides a clear view of total cost ownership for each control.

3.3 ROI Comparison (Horizontal Bar Chart)

This chart compares the return on investment across all controls.



The horizontal format improves readability and allows clear comparison of magnitude.

Task 7: Risk Treatment Timeline

4. Implementation Plan

4.1 Immediate Actions (0–30 Days)

Task	Reason
Deploy Multi-Factor Authentication (MFA)	Fast implementation and immediate risk reduction
Apply temporary WAF rules	Provides quick mitigation for critical vulnerabilities

4.2 Short-Term Actions (30–90 Days)

Task	Reason
Full WAF deployment	Addresses the largest risk exposure
Testing and tuning	Ensures optimal performance and reduces false positives

4.3 Long-Term Strategy (3–12 Months)

Task	Reason
API Security Gateway implementation	Strengthens overall API security architecture
Continuous monitoring and improvement	Maintains effectiveness of implemented controls

Key Insight

The implementation strategy prioritizes:

- Quick wins first
- High-impact controls early
- Long-term structural improvements later

Starting with low-impact controls instead of high-impact ones would be a strategic mistake.

Conclusion

This study successfully demonstrated the application of quantitative risk analysis in evaluating cybersecurity threats and guiding control selection for the SecureMobile banking platform.

Through the calculation of Annualized Loss Expectancy (ALE), I was able to clearly identify and prioritize the most critical risks facing the system. The results highlighted that not all vulnerabilities carry equal financial impact and therefore require different levels of attention and response.

The control evaluation further showed that effective cybersecurity decision-making is not based solely on technical capability, but on the ability to balance cost against measurable risk reduction. The findings confirmed that certain controls, particularly the Web Application Firewall and Multi-Factor Authentication, provide substantial financial and operational benefits when implemented strategically.

In addition, the development of visualizations and an executive dashboard ensured that complex technical and financial data could be communicated clearly to decision-makers. This is essential in real-world environments where executives require concise, data-driven insights rather than technical detail.

The phased risk treatment plan provided in this report ensures that immediate, high-impact risks are addressed first, while also establishing a foundation for long-term security improvement.

In conclusion, this work reinforces the importance of aligning cybersecurity practices with business objectives. By quantifying risk and justifying control investments with financial metrics, organizations can make informed decisions that enhance security posture while optimizing resource allocation.